

LAPORAN

Praktikum Devops

Fondasi Teoretis dan Kerangka Kerja DevSecOps



Disusun Oleh:

ARSYITA DEVANAYA ARIANTO

NRP. 3126640046

PROGRAM REKOGNISI PEMBELAJARAN LAMPAU (RPL)

JURUSAN TEKNIK INFORMATIKA

POLITEKNIK ELEKTRONIKA NEGERI SURABAYA

SURABAYA

2026

A. Tujuan dan Ruang Lingkup

Praktikum ini bertujuan untuk:

1. Menjelaskan DevSecOps sebagai sistem sosio-teknis, bukan sekadar penambahan pemindai ke dalam pipeline.
2. Memetakan praktik DevSecOps ke kelompok praktik NIST SSDF, panduan OWASP, dan jaminan rantai pasok SLSA.
3. Membedakan shift-left, shift-right, security gate, waiver berbasis risiko, serta evidence yang dapat diaudit.
4. Menyusun baseline laboratorium dan parameter lingkungan agar seluruh eksperimen pada bab berikutnya dapat direproduksi.

Ruang lingkup Bab 1 adalah landasan teori serta pembentukan lingkungan kerja: pembuatan direktori proyek, pencatatan versi komponen (Docker Engine, Docker Compose, Git, OpenSSL, curl), pencatatan `SecurityOptions` daemon Docker, dan penyusunan threat statement awal.

B. Langkah Kerja & Perintah

1) Inisialisasi Struktur Direktori Kerja

```
ubuntu123@DESKTOP-7A8ST00:/mnt/c/Users/abc/OneDrive/Desktop$ mkdir -p ~/devsecops-lab/{app,policy,reports,sbom,keys}
ubuntu123@DESKTOP-7A8ST00:/mnt/c/Users/abc/OneDrive/Desktop$ cd ~/devsecops-lab
ubuntu123@DESKTOP-7A8ST00:~/devsecops-lab$ ls
app  keys  policy  reports  sbom
ubuntu123@DESKTOP-7A8ST00:~/devsecops-lab$ |
```

Detail & Fungsi Perintah:

- **mkdir**: Perintah untuk membuat direktori (*folder*) baru di Linux.
- Opsi **-p** (*parents*): Memastikan pembuatan direktori induk jika belum ada, serta mencegah error apabila direktori sudah pernah dibuat sebelumnya.
- **Sintaks Kurung Kurawal {app,policy,reports,sbom,keys}**: *Brace expansion* pada shell Bash untuk membuat 5 sub-direktori sekaligus dalam satu baris perintah.
- **~/**: Merujuk pada *home directory* pengguna saat ini (misalnya /home/praktikan).
- **cd ~/devsecops-lab**: Mengubah direktori kerja aktif shell ke folder laboratorium yang baru saja dibuat.

Fungsi Masing-Masing Sub-Direktori:

- **app/**: Tempat menyimpan repositori kode program aplikasi (*source code*).
- **policy/**: Tempat menyimpan berkas kebijakan keamanan (*Policy-as-Code*) seperti aturan OPA (Open Policy Agent), Checkov, atau Hadolint.

- **reports/**: Tempat menampung hasil pemindaian keamanan (*scan logs/reports*) dari alat bantu seperti Trivy, SonarQube, atau Gype.
- **sbom/**: Tempat menyimpan dokumen *Software Bill of Materials* (daftar komponen dan dependensi software).
- **keys/**: Tempat penyimpanan kredensial lokal, sertifikat TLS, atau kunci kriptografi untuk penandatanganan artefak (*Cosign/GPG*).

2) Versi Tooling (Baseline Environment)

Rangkaian perintah digunakan untuk mengekstraksi versi dari setiap *engine* dan utilitas yang terpasang pada host.

```
ubuntu123@DESKTOP-7A8ST00:~/devsecops-lab$ docker version
Client:
Version:           29.3.1
API version:       1.54
Go version:        go1.25.8
Git commit:        c2be9cc
Built:             Wed Mar 25 16:12:39 2026
OS/Arch:           linux/amd64
Context:           default

Server: Docker Desktop 4.68.0 (223695)
Engine:
Version:           29.3.1
API version:       1.54 (minimum version 1.40)
Go version:        go1.25.8
Git commit:        f78c987
Built:             Wed Mar 25 16:13:48 2026
OS/Arch:           linux/amd64
Experimental:      false
containerd:
Version:           v2.2.1
GitCommit:         dea7da592f5d1d2b7755e3a161be07f43fad8f75
runc:
Version:           1.3.4
GitCommit:         v1.3.4-0-gd6d73eb8
docker-init:
Version:           0.19.0
GitCommit:         de40ad0
ubuntu123@DESKTOP-7A8ST00:~/devsecops-lab$ |
```

- **Fungsi**: Menampilkan versi lengkap dari Docker Engine, baik sisi Client maupun Server (Daemon).
- **Mengapa Detail Ini Penting**: Hasil scan kerentanan container sangat bergantung pada versi runtime Docker yang digunakan.

```
ubuntu123@DESKTOP-7A8ST00:~/devsecops-lab$ docker compose version
Docker Compose version v5.1.1
ubuntu123@DESKTOP-7A8ST00:~/devsecops-lab$
```

- **Fungsi**: Memeriksa apakah utilitas orkestrasi Docker Compose telah terpasang dan memastikan versi yang aktif adalah **v2** (berbentuk plugin terintegrasi docker compose, bukan skrip v1 terdahulu docker-compose).

```
ubuntu123@DESKTOP-7A8ST00:~/devsecops-lab$ git --version
git version 2.53.0
ubuntu123@DESKTOP-7A8ST00:~/devsecops-lab$ |
```

- **Fungsi:** Memeriksa versi *Version Control System* (VCS) Git.
- **Mengapa Detail Ini Penting:** Diperlukan untuk memastikan fitur audit jejak commit dan pengintegrasian skrip otomatisasi pipeline bekerja sesuai ekspektasi.

```
ubuntu123@DESKTOP-7A8ST00:~/devsecops-lab$ openssl version
OpenSSL 3.5.5 27 Jan 2026 (Library: OpenSSL 3.5.5 27 Jan 2026)
ubuntu123@DESKTOP-7A8ST00:~/devsecops-lab$ |
```

- **Fungsi:** Menampilkan versi pustaka dan alat perintah OpenSSL pada sistem host.
- **Mengapa Detail Ini Penting:** Digunakan untuk mengonfirmasi pustaka kriptografi yang akan menangani enkripsi, dekripsi, serta pembuatan sertifikat/kunci keamanan.

```
ubuntu123@DESKTOP-7A8ST00:~/devsecops-lab$ curl --version
curl 8.18.0 (x86_64-pc-linux-gnu) libcurl/8.18.0 OpenSSL/3.5.5 zlib/1.3.1 brotli/1.2.0 zstd/1.5.7 libidn2/2.3.8 libpsl/0.21.2 l
ibssh2/1.11.1 nghttp2/1.68.0 librtmp/2.3 mit-krb5/1.22.1 OpenLDAP/2.6.10
Release-Date: 2026-01-07, security patched: 8.18.0-ubuntu2.4
Protocols: dict file ftp ftps gopher gophers http https imap imaps ipfs ipns ldap ldaps mqtt pop3 pop3s rtmp rtsp scp sftp smb
smbs smtps telnet tftp ws wss
Features: alt-svc AsynchDNS brotli GSS-API HSTS HTTP2 HTTPS-proxy IDN IPv6 Kerberos Largefile libz NTLM PSL SPNEGO SSL threadsa
fe TLS-SRP UnixSockets zstd
ubuntu123@DESKTOP-7A8ST00:~/devsecops-lab$ |
```

- **Fungsi:** Menampilkan versi utilitas pengirim request HTTP/HTTPS curl beserta pustaka enkripsi yang didukungnya (seperti OpenSSL/LibreSSL).
- **Mengapa Detail Ini Penting:** Menguji ketersediaan utilitas untuk keperluan *API security testing* atau pengunduhan skrip otomatisasi.

3) Pemeriksaan Keamanan Kernel & Host Daemon

```
ubuntu123@DESKTOP-7A8ST00:~/devsecops-lab$ docker info --format '{{json .SecurityOptions}}'
[{"name=seccomp,profile=builtin","name=cgroupns"}]
ubuntu123@DESKTOP-7A8ST00:~/devsecops-lab$ |
```

Detail & Fungsi Perintah:

- `docker info`: Mengambil metrik teknis dan informasi tingkat tinggi mengenai konfigurasi sistem serta Docker Daemon.

- Opsi `--format '{{json .SecurityOptions}}'`: Menggunakan *Go template* untuk memfilter output dan hanya menampilkan nilai atribut `SecurityOptions` dalam format JSON yang mudah dibaca.

Hasil:

```
["name=seccomp,profile=builtin","name=cgroupns"]
```

Mekanisme Aktif:

- **Seccomp (Profile Builtin):** Kernel host membatasi **system calls** berbahaya dari container untuk melindungi kernel dari eksploitasi.
- **Cgroup Namespace:** Isolasi hirarki cgroup aktif untuk mencegah container mengakses konfigurasi resource host.

Catatan Environment Host:

Pengujian dilakukan pada lingkungan WSL2 (Ubuntu on Windows). Tidak ditemukannya modul LSM (seperti AppArmor/SELinux) pada `'SecurityOptions'` disebabkan oleh keterbatasan konfigurasi kernel bawaan WSL2. Hal ini mencatat baseline penting bahwa isolasi tingkat mandatory access control (MAC) tidak tersedia pada host ini dan harus dipertimbangkan dalam pengujian keamanan container ke depannya.

C. Hasil & Analisis

1. Verifikasi Direktori Kerja

Struktur direktori `~/devsecops-lab/` berhasil dibuat dengan pembagian area kerja:

- **app/:** Penyimpanan kode sumber aplikasi.
- **policy/:** Penyimpanan aturan tata kelola dan *Policy-as-Code*.
- **reports/:** Penyimpanan hasil pemindaian (*scan reports*).
- **sbom/:** Penyimpanan dokumen *Software Bill of Materials*.
- **keys/:** Penyimpanan kunci kriptografi dan kredensial.

Proteksi Akses: Direktori `reports`, `sbom`, dan `keys` diisolasi dan tidak dipublikasikan ke *web root* untuk mencegah kebocoran informasi sensitif.

2. Profil Keamanan Daemon & Host (SecurityOptions)

Luaran perintah `docker info --format '{{json .SecurityOptions}}'` menghasilkan:

```
["name=seccomp,profile=builtin","name=cgroupns"]
```

- **seccomp,profile=builtin:** Fitur *Secure Computing Mode* aktif menggunakan profil bawaan Docker. Profil ini memblokir sekitar 44 *system calls* (syscalls) berbahaya ke kernel Linux guna mencegah eksploitasi tingkat rendah.

- **cgroupns**: Fitur *Control Group Namespace* aktif untuk mengisolasi pandangan hirarki cgroup di dalam container, mencegah kebocoran informasi struktur resource host.
- **Kondisi Lingkungan (WSL2)**: Berdasarkan nama host (DESKTOP-7A8STOO), pengujian berjalan di atas *Windows Subsystem for Linux 2* (WSL2). Pola *SecurityOptions* ini mengonfirmasi bahwa modul LSM (*Linux Security Module*) seperti AppArmor/SELinux tidak aktif secara bawaan pada kernel WSL2.

D. Jawaban Evaluasi & Latihan Mandiri

1. Mengapa DevSecOps tidak dapat direduksi menjadi penambahan scanner pada pipeline?
Scanner hanyalah alat bantu teknis. DevSecOps mencakup integrasi budaya, tata kelola, arsitektur sistem, serta pengelolaan risiko secara berkelanjutan. Menambahkan scanner tanpa proses triase temuan, kejelasan kepemilikan risiko (*ownership*), dan budaya perbaikan otomatis hanya akan menghasilkan tumpukan *false positive* yang menghambat proses rilis aplikasi.
2. Evidence apa yang membedakan klaim kontrol dari kontrol yang benar-benar terverifikasi?
Klaim kontrol hanya berupa pernyataan kebijakan (misal: "Container tidak boleh berjalan sebagai root"). Kontrol terverifikasi membutuhkan *evidence* berwujud log konfigurasi aktual, laporan *automated compliance scan*, identitas mesin/engine penguji, serta versi rule set yang digunakan saat pemindaian dilakukan.
3. Bagaimana shared responsibility memengaruhi ownership risiko dan tindak lanjut temuan?
Shared responsibility membagi batasan tanggung jawab secara jelas antara tim platform/infrastruktur (keamanan host, daemon, dan runtime) dengan tim pengembang (keamanan kode, library, dan dependensi). Pembagian ini memastikan setiap temuan kerentanan memiliki penanggung jawab spesifik untuk melakukan remedi tanpa saling melempar tanggung jawab.

E. Kesimpulan

Praktikum ini berhasil menetapkan *baseline* laboratorium DevSecOps pada lingkungan host WSL2/Ubuntu. Perekaman versi *engine/tooling* dan pencatatan kapabilitas *SecurityOptions* (seccomp dan cgroupns) memberikan acuan baku untuk menjamin keterulangan (*reproducibility*) serta validitas pengujian keamanan pada tahapan praktikum berikutnya.